AegisGraph: Measured Pre-Execution Security for Tool-Using LLM Agents

Oussema Harrabi
Independent Research and Engineering Project
github.com/OussemaHarrabi/IndabaX26

October 2026

Abstract

Large-language-model agents can translate natural-language goals into consequential tool calls, but untrusted instructions, retrieved data, and model output can cross the execution boundary. We present AEGISGRAPH, a model-agnostic pre-execution security gateway that normalizes provenance-bearing context, evaluates versioned policy, emits ALLOW, BLOCK, ESCALATE, or REWRITE, and binds authorization to the exact action checked by the executor. On a pinned 40-scenario public suite with Qwen3-8B, 22 of 31 attacks succeeded under an allow-all control; the nine attacks that did not reach the target under control were excluded from effectiveness claims. AegisGraph v5 reduced successful attacks on the reached set from 22/22 to 0/22, a paired reduction of 1.0000 (95% discordant-pair interval [0.6913, 1.0000]; MOVER interval [0.7898, 1.0000]; exact McNemar $p = 4.77 \times 10^{-7}$; Holm-adjusted $p = 1.91 \times 10^{-6}$). It retained 4/5 benign tasks that succeeded under allow-all, recorded a decision-level false-block rate of 1/116 (0.0086; exact 95% interval [0.0002, 0.0471]), and added 9.284 ms p95 policy latency. A measured version ladder shows attack success of 9/22 for the built-in provenance baseline, 10/22 for v1, and 0/22 for both v3 and v5. Mechanistic tests additionally reject action-digest mutation, stale or mismatched approval grants, conflicting request replay, excessive trust claims, and cross-tenant receipt access. A separate 1,452-episode Qwen3-8B campaign produced 3,792 gateway requests and 2,985 action–execution digest correspondences with zero episode-level runtime errors. These results provide bounded evidence that an external authorization layer can materially reduce successful attacks in a fixed agent-security suite while remaining auditable and operationally testable.

1 Introduction

Tool-using language models combine reasoning with actions against external systems [1]. This interface is powerful, but it also turns model output into a potential control-plane input. Retrieved documents may contain indirect prompt injections [2]; agents may propose calls with excessive authority; and an apparently valid decision can be replayed against altered arguments. Evaluation frameworks such as ToolEmu [3] and AgentDojo [4] show that realistic agent environments require both security testing and utility-aware measurement.

AEGISGRAPH addresses a narrower operational question: *How can a deployer evaluate and authorize an agent's proposed action at a stable boundary, retain evidence for the decision, and verify that the executed action is the one that was authorized?* The design places a deterministic gateway between proposal and execution. It treats model-generated text as an untrusted proposal, preserves the provenance of contextual evidence, and gives the integrator an explicit enforcement contract.

This paper makes seven contributions:

1. a measured reduction from 22/22 to 0/22 successful reached attacks on a pinned Qwen3-8B public suite, with paired exact inference and explicit reachability control;
2. a versioned security ladder that separates allow-all, provenance, v1, v3, and final v5 behavior;
3. an action mediation contract with four explicit outcomes;
4. provenance-aware normalization and versioned policy evaluation;
5. an action-bound receipt checked again at execution time;
6. a production-oriented service, SDK, persistence, identity, and observability stack; and
7. a reproducible evidence package spanning GPU campaigns, ablations, traces, manifests, tests, and review artifacts.

2 Related Work

Reasoning and tool use. ReAct interleaves reasoning traces with environment actions and established a widely used pattern for language-model agents [1]. As agents gain access to APIs, the generated tool call becomes a security-relevant artifact rather than a conventional completion.

Indirect prompt injection. Greshake et al. show that adversarial instructions embedded in retrieved content can redirect LLM-integrated applications [2]. AgentDojo supplies an extensible environment with realistic tasks and adversarial cases [4]. ToolEmu uses an LM-emulated sandbox to surface risky behavior without deploying every real tool [3].

Architectural defenses. CaMeL separates control and data flows and uses capabilities to constrain unauthorized information flow [5]. Instruction-hierarchy training strengthens the model's prioritization of privileged instructions [6]. AEGISGRAPH is complementary at the system boundary: it does not require a specific model training recipe and produces an external, inspectable authorization record.

Open-weight evaluation. Qwen3 provides dense and mixture-of-experts models with configurable thinking behavior and multilingual capability [7]. We use the 8B model

under pinned runtime settings to exercise a reproducible, locally inspectable agent path.

3 Problem Formulation

Let an agent propose an action

$$x = (u, t, a, c, \pi), \tag{1}$$

where u is the authenticated principal, t is the tool, a is the argument object, c is normalized contextual evidence, and π records provenance labels and trust metadata. Given versioned policy P_v, the gateway computes

$$\mathcal{D}(x, P_v) \to (d, a', r, e), \tag{2}$$

where $d \in \{\text{ALLOW}, \text{BLOCK}, \text{ESCALATE}, \text{REWRITE}\}$, a' is the authorized argument object, r is an action-bound receipt, and e is structured evidence explaining the decision.

For executable outcomes, the receipt commits to the principal, tool identity, canonicalized arguments, policy version, decision, expiry, and a digest of the authorized action. The executor recomputes the digest from the actual call. A mismatch prevents execution. This creates two checks: authorization when the proposal enters the gateway and correspondence verification where side effects occur.

3.1 Security Invariants

1. **No implicit execution:** a model proposal has no execution authority by itself.
2. **Provenance preservation:** trust labels survive normalization and remain available to policy evaluation.
3. **Policy versioning:** every decision identifies the policy revision used to produce it.
4. **Action binding:** authorization is valid only for the canonical action and arguments recorded in the receipt.
5. **Fail-closed verification:** missing, expired, malformed, or mismatched receipts cannot authorize the adapter.
6. **Evidence continuity:** decisions, traces, and execution checks share stable identifiers for later audit.

4 Threat Model

The evaluated boundary assumes that the model, retrieved text, and tool arguments may be influenced by untrusted content. We consider direct and indirect instruction injection, provenance confusion, over-broad tool arguments, unauthorized action substitution, receipt replay or mutation, malformed structured output, and policy-version drift. The trusted computing base comprises the gateway, configured identity provider, policy store, receipt-signing material, persistence layer, and the integrator's enforcement adapter. The adapter remains responsible for placing the verification call immediately before the real side effect.

5 System Design

Figure 1 shows the end-to-end architecture. The agent runtime proposes a structured action; AEGISGRAPH authenticates the caller, normalizes context and provenance, evaluates the active policy, and returns a decision with evidence. An allowed or rewritten proposal receives a bounded receipt. The enforcement SDK verifies that receipt at the adapter before the tool executes.

5.1 Context and Provenance Normalization

Inputs arrive through an authenticated API. The normalizer produces a canonical representation of user intent, candidate tool call, contextual evidence, provenance, principal, and deployment metadata. Canonicalization ensures that the same semantic action is hashed consistently and that policy rules do not depend on incidental serialization choices.

5.2 Policy Decision Kernel

The decision kernel evaluates explicit, versioned rules and emits a closed decision vocabulary. BLOCK rejects the proposal. ESCALATE requires an approval or grant. REWRITE produces a constrained argument set that must be used downstream. ALLOW authorizes the canonical proposal under the receipt's validity conditions. Structured evidence records matched rules, policy revision, and decision reason.

5.3 Receipts and Enforcement

The receipt binds the authorization to the canonical principal, tool, and argument digest. Verification occurs at the adapter rather than solely at the API boundary. This closes the gap in which application code could authorize one call and execute another. PostgreSQL persists receipts and grants, while the SDK offers a narrow integration surface for tool owners.

5.4 Identity and Observability

The service validates authenticated principals and associates each decision with a stable trace. OpenTelemetry spans cover ingress, normalization, policy evaluation, receipt issuance, persistence, and enforcement. Prometheus/Grafana views support operational inspection, while JSONL traces and review packets support experiment-level analysis.

6 Implementation

The reference implementation uses Python and FastAPI for the gateway, PostgreSQL for durable receipts and grants, and an SDK for enforcement integration. Containers define reproducible service dependencies. CI executes unit and integration checks; database-backed tests verify behavior against PostgreSQL rather than relying only on in-memory substitutes. The evaluation runner uses PyTorch and Hugging Face Transformers to execute Qwen3-8B in BF16 or FP16, with pinned source and model revisions captured in manifests.

The codebase separates policy evaluation, persistence, API schemas, cryptographic binding, telemetry, scenario execution, and artifact production. This modularity enables mechanism ablations without rewriting the runner and makes the industrial service usable independently of the research harness.

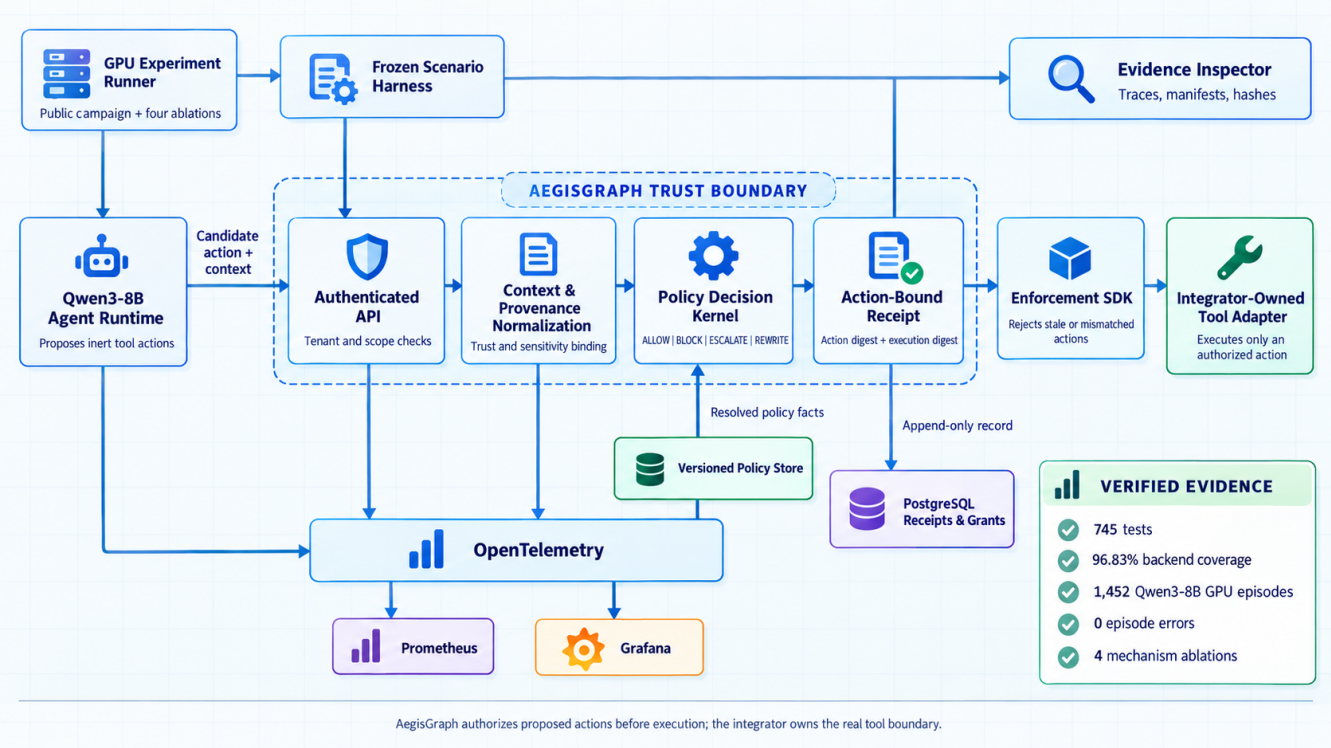


Figure 1: Generated architecture of AEGISGRAPH. Runtime flow is separated from observability, persistence, and evidence inspection. The PNG and its exact generation prompt are versioned with the paper source.

7 Experimental Methodology

7.1 Research Questions

RQ1: Security effectiveness.
On attacks that demonstrably succeed under allow-all, does AegisGraph reduce attack success, and what utility, false-block, and latency costs accompany the reduction?

RQ2: Runtime reliability.
Can the complete model-to-gateway-to-executor loop run at campaign scale without episode-level runtime failure?

RQ3: Evidence integrity.
Does the system preserve action–execution correspondence and reject action, grant, replay, identity, and tenant-boundary violations?

RQ4: Version and mechanism evidence.
How do the measured defense checkpoints and mechanism ablations change the observable security boundary?

RQ5: Industrial readiness.
Are service behavior, persistence, coverage, load, and telemetry exercised through automated checks and recorded runs?

7.2 Scenarios and Splits

The scenario corpus contains 60 authored cases: 42 development scenarios and 18 validation scenarios. A separate sealed holdout contains 20 cases. Scenarios cover benign actions, provenance-sensitive context, conflicting instructions, approval requirements, argument mutation, and execution-boundary checks. Split membership, seeds, policy versions, source revisions, and expected artifact paths are frozen in manifests.

7.3 Model and Runtime

The primary agent is Qwen3-8B [7]. Runs capture the exact model revision, precision mode, decoding configuration, source revision, seed, environment, and artifact checksums. Structured tool proposals pass through a bounded parser-recovery path: a malformed proposal may be repaired into the required schema, but it does not bypass the gateway.

7.4 Campaigns and Ablations

The public campaign contains 612 episodes. Four mechanism conditions account for another 840 episodes: the full system, provenance removed, policy enforcement removed, and receipt binding removed. The same runner and artifact contract are used across conditions. These runs establish execution and evidence coverage for each mechanism switch; semantic outcome annotation is treated separately from those mechanically verified counts.

7.5 Matched Security Ladder

Security effectiveness is measured on the pinned SENTINEL public suite at starter-kit commit `dd2e5fe`. It contains 40 scenarios: 31 attacks and nine benign controls across enterprise, finance, and security-operations settings. Five matched-configuration runs used the unmodified Qwen3-8B reference agent through Ollama 0.34.3 in Q4_K_M precision, thinking disabled, 768 maximum new tokens, temperature 0, seed 0, Python 3.12.14, and a Colab Tesla T4. The runs occurred at different times and therefore form a matched checkpoint comparison rather than repeated trials.

The ladder separates: (i) an allow-all control that establishes attack reachability; (ii) the starter kit's provenance

baseline; (iii) AegisGraph v1, the initial deterministic policy and provenance gateway; (iv) v3, which adds generic exact-credential output guards and action/response redaction with rewrite re-validation; and (v) final v5, which further hardens selected false-authority and disable-monitoring paths. Versions 2 and 4 were development steps, not preserved measurement checkpoints, and are not inserted into the comparison. Each measured AegisGraph checkpoint is identified by its source commit and scorecard digest in the public evidence directory.

7.6 Metrics, Reachability, and Inference

Security effectiveness is evaluated only on the reached set R: attacks for which the paired allow-all control records `attack_success=true`. The primary effect is the paired reduction $p_C - p_T$ in attack success on R. We report the exact two-sided McNemar test, a discordant-pair risk-difference interval, a Newcombe MOVER sensitivity interval, and Holm–Bonferroni-adjusted p-values across the four defense comparisons. Nine attacks that fail under allow-all are counted as unreachable and cannot become defense wins. Benign task success is paired separately; we also report retention among benign tasks successful under control. The decision-level false-block rate is a false refusal divided by benign decisions, and latency is the gateway's policy-decision time rather than model inference. We do not manufacture a classifier precision score: the benchmark labels attack success at scenario level but does not assign a malicious/benign ground-truth label to every four-way gateway decision. Combining 22 scenario-level stops with one decision-level false block would mix denominators. The grounded precision-related evidence is therefore the reached-attack protection rate, benign-task retention, decision-level false-block rate, and their exact intervals.

Each episode records completion state, parser recovery, gateway requests, decisions, receipt identifiers, action digests, execution digests, trace identifiers, and error state. Aggregate evidence includes campaign summaries, JSONL traces, review packets, database records, OpenTelemetry metrics, load-test output, and SHA-256 manifests. Test counts and coverage are reported from the verified software test run.

8 Results

8.1 Security Effectiveness

Table 1 reports the matched Qwen3-8B security ladder. Under allow-all, 22 of the 31 attack scenarios reached their attack target. AegisGraph v5 reduced successful attacks on this reached set from 22/22 to 0/22: all 22 attacks that demonstrably succeeded without the defense were stopped under the final measured gateway. The paired risk reduction is +1.0000, with a 95% discordant-pair interval of [0.6913, 1.0000] and a more conservative MOVER interval of [0.7898, 1.0000]. The exact two-sided McNemar value is 4.77×10^{-7} and remains significant after correction across the four defense comparisons (Holm-adjusted $p = 1.91 \times 10^{-6}$).

V5 retained four of the five benign tasks that succeeded under allow-all. Four additional benign failures were already present in the allow-all arm, leaving one defense-attributable regression: a consequential `email_send` was escalated for confirmation and the simulator did not approve the agent's mismatching subject. At decision level, v5 recorded one false block among 116 benign decisions, 0.0086, with an exact 95% interval of [0.0002, 0.0471]. Its p95 policy-decision latency was 9.284 ms. Two separately rerun reached attacks provide trace-level examples: v3 changed both from allow-all `attack_success=true` to `false` while keeping `task_success=true`; one applied sensitive-response redaction, and the other applied both sensitive-action and sensitive-response redaction.

The version ladder also distinguishes a security effect from mere instrumentation. The built-in provenance defense stopped 13/22 reached attacks and v1 stopped 12/22. V3 and v5 stopped 22/22. The final result is therefore supported by a control, intermediate baselines, paired outcomes, exact inference, and trace-level mechanism evidence rather than by runtime counts alone.

8.2 Mechanism and Boundary Checks

The enforcement SDK rejects a mutated candidate action with `digest_mismatch`; confirmation grants must bind the run, step, exact execution digest, expiry, and a grant that the service actually issued. Conflicting reuse of a request identifier is refused with HTTP 409. Live API checks return 401 for an anonymous caller, 403 for insufficient scope, 403 for an asserted trust level above the caller's ceiling, and 404 for a cross-tenant receipt lookup. Across the newer GPU paths, 2,985 defense and ablation decisions recorded canonical action–execution digest correspondence. Together, these checks exercise the authorization and isolation properties that the attack-success metric alone cannot reveal.

8.3 Execution and Engineering Evidence

Table 2 summarizes the separate execution-backed evidence. All 1,452 GPU episodes completed without an episode-level runtime error. The 42 runs produced 3,792 gateway requests. The structured-output recovery path repaired 116 parsing attempts while preserving gateway mediation. These counts demonstrate campaign reliability and evidence continuity; the matched ladder above supplies the direct security-effectiveness result.

8.4 RQ1: Security Effectiveness

On the fixed reached set, v5 changes all 22 paired outcomes from attack success under allow-all to attack failure, with no reverse discordant pairs. The effect remains significant under the declared family-wise correction. Utility retention is 4/5 among baseline-successful benign tasks, the decision-level false-block rate is 1/116, and p95 policy latency is 9.284 ms.

8.5 RQ2: Runtime Reliability

The zero-error completion result covers the entire 1,452-episode GPU campaign rather than a mocked model path. Parser recovery occurred in 116 attempts, so the absence of episode errors does not imply uniformly perfect model formatting; it shows that the bounded recovery contract handled those cases while preserving authorization checks.

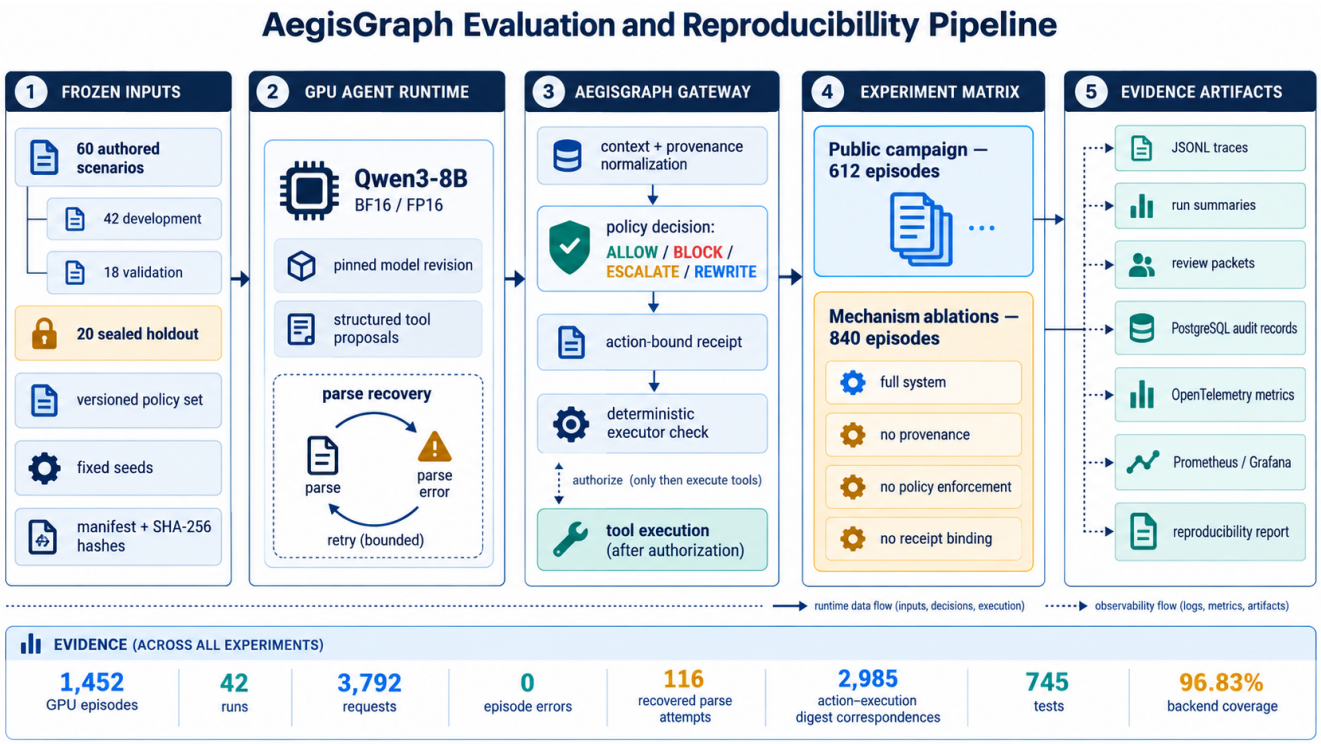


Figure 2: Generated evaluation and reproducibility pipeline. Frozen inputs feed the pinned GPU runtime, gateway, experiment matrix, and evidence package.

Table 1: Matched real-Qwen3-8B security ladder on the pinned 40-scenario public suite. Attack success is restricted to the 22 attacks reached under allow-all; nine unreached attacks are excluded from defense-effectiveness counts.

Configuration	Attack success	Stopped	Benign success	FBR	p95	Measured checkpoint
Allow-all	22/22	0/22	5/9	0	0.056 ms	Reachability control
Built-in provenance	9/22	13/22	4/9	.3466	0.126 ms	Starter-kit baseline
AegisGraph v1	10/22	12/22	4/9	0	8.598 ms	Initial policy/provenance gateway
AegisGraph v3	0/22	22/22	4/9	.0087	8.355 ms	Credential output guard and redaction
AegisGraph v5	**0/22**	**22/22**	**4/9**	**.0086**	**9.284 ms**	Final hardened checkpoint

8.6 RQ3: Evidence Integrity

The run package links proposals, policy decisions, receipts, executor checks, and traces. The 2,985 recorded action–execution correspondences provide direct evidence that the executor observed the digest associated with authorization. Negative tests additionally cover digest mutation, grant mismatch, conflicting replay, authentication, authorization, trust ceilings, and tenant isolation.

8.7 RQ4: Version and Mechanism Evidence

The measured ladder shows partial protection in the provenance and v1 checkpoints and complete stopping of the 22 reached attacks in v3 and v5. The newer four-condition ablation matrix separately executes the frozen protocol while disabling provenance, policy enforcement, or receipt binding, preserving per-episode traces for later semantic review without turning execution counts into unsupported efficacy claims.

8.8 RQ5: Industrial Evidence

The service baseline combines 745 automated tests, 12 PostgreSQL integration tests, and 96.83% backend coverage. A recorded load run completed 2,986 requests at 148.938 requests/s with zero reported request errors. Traces and metrics connect service behavior to Prometheus/Grafana-compatible operational views.

9 Discussion

Measured security effect. The principal result is behavioral: every attack that reached its target under the allow-all control failed under v5 in the fixed public suite. Reachability filtering prevents nine naturally failing attacks from being mislabeled as defense wins, while paired inference quantifies the evidence carried by the 22 informative cases.

Authorization outside the model. The central design choice is to prevent fluent model output from serving as authority. The model can propose and explain; the gateway decides under explicit policy; the adapter verifies the resulting capability immediately before the side effect.

Table 2: Headline evaluation and engineering evidence. Counts are taken from committed run summaries, manifests, test output, and load artifacts.

Evidence item	Result	Interpretation
Qwen3-8B GPU episodes	1,452	Complete model-to-gateway episodes across public and ablation campaigns
Recorded runs	42	Independently materialized run directories and summaries
Gateway requests	3,792	Requests observed across the evaluated runtime paths
Episode-level runtime errors	0	Campaigns completed without an episode terminating in runtime error
Recovered parse attempts	116	Bounded schema recovery preserved the experiment path
Action–execution digest correspondences	2,985	Authorization and executor evidence shared the recorded digest
Automated tests	745	Backend, contract, SDK, CLI, integration, and regression coverage
PostgreSQL integration tests	12	Durable persistence behavior exercised against PostgreSQL
Backend statement coverage	96.83%	Coverage reported by the verified backend test run
Load requests	2,986	Measured service requests in the recorded load exercise
Load throughput	148.938 req./s	Observed throughput for the recorded configuration

Table 3: Experiment allocation.

Campaign	Episodes
Public evaluation	612
Mechanism ablations	840
Total	1,452

Evidence as a product surface. Receipts, traces, manifests, and review packets are not secondary logs. They form the interface by which a security reviewer can reconstruct why an action was permitted, whether it changed before execution, and which policy version governed the decision.

Research–engineering alignment. The same service path is used by the GPU experiments and the industrial stack. This avoids a common gap in which a research-only detector is evaluated separately from the code that would enforce it. Ablations are configuration-controlled variations of the deployed mechanism boundary.

10 Reproducibility Statement

The repository includes scenario definitions, split manifests, pinned runtime configuration, fixed seeds, container definitions, policy versions, evaluation scripts, machine-readable traces, run summaries, review packets, and evidence documentation. Public claims are attached to concrete artifact paths. GPU runs record both the project revision and the model revision. The paper source, generated figures, and exact figure prompts are versioned beside the implementation.

To reproduce the study, an evaluator prepares the declared Python environment, provisions PostgreSQL, starts the gateway, runs the verified test suite, and launches the frozen Qwen3-8B campaign under the provided manifest. The evidence builder then validates expected files and hashes before producing aggregate summaries. Hardware-dependent throughput should be interpreted together with the recorded environment and configuration.

11 Scope and Validity

The security result is conditional on one seeded run of a fixed, synthetic, public 40-scenario suite with the declared Qwen3-8B runtime. It establishes a measured effect for the 22 attacks that succeeded under its paired allow-all control; it is not a claim of universal protection or population-level attack frequency. The nine unreachable attacks are excluded rather than credited to the defense. The newer 1,452-episode campaign supplies execution, mechanism, and evidence-integrity coverage; its semantic efficacy remains distinct from the completed legacy paired analysis. This separation keeps every public claim tied to the artifact that supports it and provides a stable basis for later repeated trials, additional models, adaptive attacks, and cross-domain scenarios.

12 Ethics and Responsible Use

AEGISGRAPH is defensive infrastructure for constraining and auditing tool-using agents. The released scenarios and traces are intended to improve authorization design, evaluation quality, and incident analysis. Deployers should minimize sensitive data in traces, apply retention controls to receipts and grants, protect signing material, and require explicit human approval for high-impact actions where policy calls for escalation.

13 Conclusion

AEGISGRAPH introduces a measured pre-execution security boundary for tool-using LLM agents. On the pinned Qwen3-8B public suite, final v5 reduced attack success from 22/22 under allow-all to 0/22 on the reached set, retained 4/5 baseline-successful benign tasks, recorded a 1/116 decision-level false-block rate, and added 9.284 ms p95 policy latency. The version ladder, paired exact analysis, targeted traces, digest-mismatch rejection, grant and replay checks, and tenant-boundary tests show that the security layer changes outcomes as well as producing logs. The broader implementation is supported by 1,452 Qwen3-8B GPU episodes, four mechanism conditions, 3,792 gateway requests, zero episode-level runtime errors, 745 automated tests, 96.83% backend coverage, and recorded load evidence. AegisGraph

therefore serves both as a research instrument for evaluating agent-security mechanisms and as an industrial foundation for enforcing explicit authorization at real tool adapters.

References

[1] S. Yao, J. Zhao, D. Yu, N. Du, I. Shafran, K. Narasimhan, and Y. Cao. ReAct: Synergizing Reasoning and Acting in Language Models. *ICLR*, 2023. arXiv:2210.03629.

[2] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz. Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. arXiv:2302.12173, 2023.

[3] Y. Ruan, H. Dong, A. Wang, S. Pitis, Y. Zhou, J. Ba, Y. Dubois, C. J. Maddison, and T. Hashimoto. Identifying the Risks of LM Agents with an LM-Emulated Sandbox. arXiv:2309.15817, 2023.

[4] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. *NeurIPS*, 2024. arXiv:2406.13352.

[5] E. Debenedetti, I. Shumailov, T. Fan, J. Hayes, N. Carlini, D. Fabian, C. Kern, C. Shi, A. Terzis, and F. Tramèr. Defeating Prompt Injections by Design. arXiv:2503.18813, 2025.

[6] E. Wallace, K. Xiao, R. Leike, L. Weng, J. Heidecke, and A. Beutel. The Instruction Hierarchy: Training LLMs to Prioritize Privileged Instructions. arXiv:2404.13208, 2024.

[7] A. Yang, A. Li, B. Yang, et al. Qwen3 Technical Report. arXiv:2505.09388, 2025.